Microsoft Purview HIPAA Compliance Program

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

Contents

Executive Summary — Microsoft Purview HIPAA Compliance Program 5

The problem . . . 5

The solution . . . 5

How it works . . . 5

What you get . . . 5

The boundary (why this is honest) . . . 5

Bottom line . . . 6

1. Solution Overview — Microsoft Purview HIPAA Compliance Program 6

What this solution is . . . 6

Why this matters . . . 7

How it works . . . 7

The HIPAA safeguard → Purview control map (the technical method, not the ruling) . . . 8

The role-separation model (least privilege) . . . 9

What you can control . . . 9

Limitations (be honest with buyers) . . . 9

Naming convention (used in every doc and script) . . . 10

The standard deployment model . . . 11

2. Requirements Guide — Microsoft Purview HIPAA Compliance Program 11

2.1 Licensing — Compliance Manager premium templates (HIPAA/HITECH, HITRUST CSF) . . . 11

2.2 Compliance Manager role groups populated with least-privilege separation . . . 12

2.3 Named HIPAA compliance, privacy, security & legal owners (applicability + adequacy) . . . 12

2.4 In-scope ePHI, workloads, and the safeguard → control map decided . . . 12

2.5 Improvement-action owners and evidence sources identified . . . 13

2.6 Automatic-testing decision and the underlying technical safeguards . . . 13

2.7 Security & Compliance PowerShell + Microsoft Graph toolchain . . . 13

2.8 A pilot assessment and change control . . . 13

Global Requirements — Microsoft Purview Solutions 14

1. Microsoft 365 tenant with the required Purview/compliance licensing . . . 14

2. Purview roles (least-privilege) and portal access . . . 14

3. Security & Compliance PowerShell + Graph toolchain . . . 15

4. Data sources & scope in scope . . . 15

5. Compliance, records, privacy & legal stakeholders . . . 15

6. A pilot scope and change control . . . 15

3. Implementation Guide — Microsoft Purview HIPAA Compliance Program 16

Step 1 — Baseline the posture and capture role/licensing readiness (Assess) . . . 16

Step 2 — Assign roles with least-privilege separation (Configure — guardrails) . . . 17
Step 3 — Design the assessment, scope, and safeguard map (Design) . . . 17
Step 4 — Create the pilot assessment (Configure — pilot-first) . . . 18
Step 5 — Build the improvement-action plan and evidence register (Configure) . . . 18
Step 6 — Enable automatic testing where it applies (Configure) . . . 18
Step 7 — Validate the evidence behind each safeguard (Pilot → Validate) . . . 19
Step 8 — Expand to the full HIPAA program and run the cadence (Expand) . . . 19
5. Testing Guide — Microsoft Purview HIPAA Compliance Program 20
Test 1 — Role separation is in place (the access guardrail) . . . 20
Test 2 — Licensing supports the HIPAA (and HITRUST) template . . . 20
Test 3 — The pilot assessment exists and is scored . . . 21
Test 4 — Every pilot action has an owner, target date, status, mapped safeguard, and evidence source . . . 21
Test 5 — Automatic testing reflects the real technical safeguard state (true evidence) . . . 21
Test 6 — A not-yet-implemented safeguard scores as such (no false pass) . . . 21
Test 7 — Manual evidence is attached and defensible . . . 21
Test 8 — Control mapping / shared controls behave as expected (evidence once, score many) . . . 21
Test 9 — Posture report is accurate and complete . . . 22
Test 10 — Safe automation defaults . . . 22
6. Troubleshooting — Microsoft Purview HIPAA Compliance Program 22
The HIPAA/HITECH (or HITRUST CSF) template is not available to create . . . 22
`Connect-IPPSSession` or `Connect-MgGraph` fails . . . 23
A role group "could not be read" or a name looks wrong . . . 23
Separation-of-duties flag: someone is Administrator AND Contributor . . . 23
The score didn't change after I "implemented" a safeguard . . . 23
A safeguard shows implemented but `CMPHIPAA-Validation.ps1` says the control is ABSENT . . . 23
Automatic testing isn't updating an action . . . 24
`CMPHIPAA-Configuration.ps1` reports rows as FAIL . . . 24
I expected the scripts to create the assessment / set action status — they didn't . . . 24
Shared controls didn't credit across HITECH and HITRUST/NIST . . . 24
A high-impact technical remediation caused disruption . . . 25
Rollback . . . 25
7. Best Practices — Microsoft Purview HIPAA Compliance Program 25
Program & governance . . . 25
Configuration discipline . . . 26
Evidence & audit-readiness . . . 26
HR/privacy-sensitive controls (Insider Risk & Communication Compliance) . . . 26

Lifecycle & maintenance 27
8. Deliverables Summary — Microsoft Purview HIPAA Compliance Program 27
Documents 27
PowerShell tools (5) — Security & Compliance PowerShell / Microsoft Graph 28
Named artifacts this program creates/tracks 29
Outcomes 29
Explicitly out of scope (governance determinations, not technical outputs) 30
Appendix A — PowerShell Scripts 31

Executive Summary — Microsoft Purview HIPAA Compliance Program

The problem

"Are we HIPAA-compliant?" has no defensible answer without a **scored, control-by-control map** and the **evidence** to back it. HIPAA's Security Rule is a set of Administrative, Physical, and Technical safeguards; left unmapped, the organization's posture is a guess — a compliance gap and a data-risk exposure that surfaces at the worst time, in an OCR investigation, a business-associate audit, or a breach.

The solution

A **HIPAA-aligned compliance program built inside Microsoft Purview**. It maps the HIPAA Security Rule safeguards (with HITECH/Breach-Notification and, where scoped, **HITRUST CSF**) to the Microsoft Purview technical controls that satisfy them — **Audit**, **sensitivity labels**, **DLP for ePHI**, **retention**, **sensitive information types**, and, where scoped, **Insider Risk** and **Communication Compliance** — and measures the whole program with **Compliance Manager**. The result is a **Compliance Score**, a safeguard → control map, an improvement-action plan with owners, and an **audit-ready evidence register**: configured, piloted where high-impact, validated, and defensible. It uses only the Microsoft Purview portal, Security & Compliance PowerShell, and Microsoft Graph — no third-party tooling.

How it works

Assess → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand.** Baseline the posture and role/licensing readiness; design the assessment, ePHI scope, and safeguard map with the HIPAA officers; assign least-privilege separated roles; create the HITECH pilot assessment and build the action plan and evidence register; enable automatic testing where eligible; validate the technical evidence behind each safeguard — piloting any new high-impact control in simulation/test first; then expand to the full program and run a maintenance cadence, leaning on shared controls so you **evidence once and score many**.

What you get

- A **scored HIPAA program** in Compliance Manager with a safeguard → Purview control map.
- An **auditor-ready evidence register** — owner, status, test date, and proof per safeguard.
- **Least-privilege role separation** proven and snapshotted.
- **Five PowerShell tools** (read-only or `-WhatIf` by default; no secrets) for discovery, plan/evidence structuring, technical validation, posture reporting, and role scope.
- Full documentation: requirements, step-by-step implementation with pass/fail gates and rollback, a testing guide, troubleshooting, and best practices.

The boundary (why this is honest)

Compliance Manager **measures; it does not enforce**. Whether a safeguard **applies**, how each **addressable** specification is met, the outcome of your **risk analysis**, and whether the evidence **satisfies** the obligation are **compliance, privacy, and legal determinations** — this program provides the technical method and the proof, not the ruling. Premium templates and several controls are **E5 / E5 Compliance-gated**; availability is verified against your licensing, never assumed. High-impact technical changes are piloted in **simulation/test** under change control.

Bottom line

Meet HIPAA with a Purview-backed program — control mapping, configured controls, and audit evidence — delivered, validated, and defensible in Microsoft Purview, at a fraction of the cost of a bespoke consulting engagement.

1. Solution Overview — Microsoft Purview HIPAA Compliance Program

What this solution is

This solution stands up a **HIPAA-aligned compliance program inside Microsoft Purview**: it maps the **HIPAA Security Rule** safeguards (and the HITECH/Breach-Notification and, where scoped, HITRUST CSF overlays) to the **Microsoft Purview** technical controls that satisfy them, measures the program with **Compliance Manager**, and produces the **evidence** — owners, implementation status, test status, and proof — that makes the posture **defensible**. The output is a scored, control-by-control HIPAA program with a control map, an improvement-action plan, an evidence register, and a posture report — configured, piloted where high-impact, and validated.

It is the **program umbrella**, not a single control: it uses **Compliance Manager** (the **HIPAA/HITECH** assessment template, plus **HITRUST CSF** where entitled) to score, and it maps each safeguard to the Purview capability that evidences it — **Audit**, **sensitivity labels**, **Data Loss Prevention (DLP)**, **data lifecycle / retention**, **sensitive information types**, and (where scoped) **Insider Risk Management**, **Communication Compliance**, and **eDiscovery/legal hold**. It uses only the **Microsoft Purview portal** (`purview.microsoft.com`), **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** — no third-party tooling.

> ***This is a program, not a determination.*** *Purview and Compliance Manager give you the* ***measurement, control mapping, and evidence****. Whether a given safeguard is* ***required*** *or* ***addressable*** *for your organization, how you satisfy an addressable specification, the outcome of your* ***risk analysis****, and whether the collected evidence* ***satisfies*** *your HIPAA obligation are* ***compliance, privacy, security, and legal determinations*** *— this solution provides the technical method and the proof, not the ruling.*
>
> ***Distinct from the endpoint / DLP HIPAA products.*** *A HIPAA* ***endpoint*** *or* ***PHI DLP*** *solution configures a *specific* control (device policy, or DLP for electronic PHI).* ***This program sits above them****: it maps *all* the HIPAA Security-Rule safeguards to Purview controls, scores the whole program in Compliance Manager, and collects the cross-control evidence. It* ***references*** *the individual technical controls; it does not re-implement each one — where a safeguard needs a high-impact technical change (a new DLP, label, or retention policy), that change is* ***piloted in simulation/test*** *under its own*

*solution and change control, and this program **evidences** that it is in place.*

Why this matters

• **"Are we HIPAA-compliant?" has no defensible answer without a scored control map.** HIPAA's Security

Rule is a set of **Administrative, Physical, and Technical safeguards** (§164.308/310/312) plus organizational and documentation requirements (§164.314/316). Compliance Manager turns that into a **measured score** with a per-control status and evidence, so gaps are **visible, owned, and tracked** instead of discovered in an audit or a breach investigation.

• **Evidence is what an OCR investigation or a business associate audit asks for.** A posture is only

defensible if each safeguard carries **who owns it, whether it is implemented, when it was tested, and the proof**. This program centralizes that record — audit-log configuration, DLP for ePHI, labels, retention, access controls — so producing it is a routine, not a fire drill.

• **Control mapping means you evidence once and score many.** One well-implemented control — unified

audit logging, say — satisfies HIPAA §164.312(b) *and* maps across HITRUST, NIST, and your internal baseline in Compliance Manager's **shared-control** model. You fix once and the score updates in every assessment that shares the control.

• **Applicability and adequacy are not technical calls.** *Which* safeguards apply, how each

addressable specification is met, and *whether* the evidence is sufficient are **compliance/privacy/legal** determinations. This program supplies the configuration method and the evidence; it does not decide sufficiency.

How it works

1. **Baseline the posture (Assess).** Confirm licensing and the Compliance Manager role groups, capture

the current **Compliance Score** and technical-control state (audit on/off, DLP/label/retention presence), and record the readiness snapshot (`HIPAA Roles – Separation Evidence`).

1. **Design the assessment, scope, and safeguard map (Design).** With compliance/privacy/legal

stakeholders, confirm the **in-scope assessment template** (HIPAA/HITECH, plus HITRUST CSF where entitled), the **scope** (workloads holding ePHI, the systems in scope), and the **safeguard-to-Purview control map** (`HIPAA Control Map – Safeguards`, `HIPAA Scope – Record`). Applicability is the stakeholders' determination.

1. **Populate roles with separation (Configure — guardrails).** Assign the Compliance Manager role groups

least-privilege so program **administrators** are separated from action **contributors** and read-only **readers/auditors** — the auditable access record for the evidence you produce.

1. **Create the assessment and build the action plan (Configure).** Create `HIPAA Assessment – HITECH –

Pilot `from the template, then build the` **`improvement-action plan`** (HIPAA Action Plan – Pilot`): each action mapped to its safeguard, assigned an **owner**, a **target date**, an **implementation status**, and a **test status**, with **evidence** attached.

1. **Turn on automatic testing where it applies (Configure).** Compliance Manager can **auto-test**

eligible actions by reading Microsoft 365 configuration signals (`HIPAA Automatic Testing – Setting`); enable it so technical safeguards update their status without manual re-checks. Availability is plan/action-dependent — verify.

1. **Validate the evidence behind the safeguards (Pilot → Validate).** Confirm the **technical state**

backing the mapped controls — **audit enabled**, **DLP for ePHI present**, **sensitivity labels / encryption**, **retention**, **Conditional Access / MFA** — matches what the assessment claims; attach evidence and set test status/date. Pilot any *new* high-impact technical control in **simulation/test** first, under its own change control.

1. **Report and expand (Validate → Expand).** Roll up the score, safeguard-status breakdown, and evidence

register (`HIPAA Posture – Report`); then add the remaining production assessment(s), lean on shared controls, and stand up the **maintenance cadence** (re-test, re-evidence, review owners, watch template/regulation updates).

The HIPAA safeguard → Purview control map (the technical method, not the ruling)

This is the **method** for evidencing each safeguard with a Purview capability. *Whether* a safeguard applies and *how* an **addressable** specification is satisfied are compliance/privacy/legal determinations; **verify feature availability against your licensing/tenant**.

HIPAA Security Rule safeguard	Purview capability that evidences it
Audit controls — §164.312(b)	**Purview Audit** (unified audit log ingestion on; Audit Premium where entitled)
Access control — §164.312(a)	**Sensitivity labels** (+ encryption), **DLP**, and **Conditional Access / MFA** (Entra)
Person/entity authentication — §164.312(d)	**Conditional Access / MFA** evidence (Entra, via Graph)
Transmission security — §164.312(e)	**Message encryption**, label-based encryption, **DLP** on ePHI in transit
Integrity — §164.312(c)	**Data lifecycle / retention** and records controls; label protection
Information access management — §164.308(a)(4)	**DLP** + **sensitivity labels** scoping access to ePHI
Identify ePHI (basis for many safeguards)	**Sensitive information types** (U.S. health/HIPAA SITs) + **classification**
Contingency / data availability — §164.308(a)(7)	**Retention** policies preserving ePHI-bearing content
Security incident / monitoring — §164.308(a)(6)	**Insider Risk Management**, **Communication Compliance** (where scoped; HR/privacy-gated)

HIPAA Security Rule safeguard	Purview capability that evidences it
Breach investigation / legal hold — §164.400–414	**eDiscovery** + **legal hold** for evidence preservation
Documentation / evaluation — §164.308(a)(8), §164.316	**Compliance Manager** evidence store + posture report

> *Insider Risk Management and Communication Compliance are **HR/privacy-sensitive** — configure them **privacy-by-design** (pseudonymization where available, strict **role separation**), and defer all case **outcomes** to HR/legal. This program evidences that the *capability* exists, not any case action.*

The role-separation model (least privilege)

Role group	Who	Can (typical)
Compliance Manager Administrators	Program owners / IT config	Read and edit all Compliance Manager data; manage settings, templates, role assignment
Compliance Manager Assessors	Assessment leads	Read data, **create assessments**, implement actions, edit **test** status
Compliance Manager Contributors	Safeguard/action owners	Read data, create assessments, **edit improvement actions** (not test status)
Compliance Manager Readers	Oversight / auditors / HIPAA Security Officer review	**Read-only** access

> *Global Administrator, Compliance Administrator, and Compliance Data Administrator also have access. **Verify the exact role-group names and rights in your tenant** — Purview role naming evolves; do not assume. The HIPAA **Security Officer** and **Privacy Officer** are typically *readers/oversight*, with configuration done by least-privilege assessors/contributors.*

What you can control

- The **in-scope assessment template(s)** — HIPAA/HITECH (and HITRUST CSF where entitled) — and how

assessments are **grouped**.

- The **safeguard-to-control map** and the **improvement-action plan** — owners, target dates,

implementation status, test status, and the **evidence** attached to each action.

- Whether **automatic testing** of eligible actions is on, so technical safeguards self-update.
- The **role-group membership** enforcing least-privilege separation.
- The **pilot subset** (one HIPAA assessment) validated first before the full program is expanded.

Limitations (be honest with buyers)

• **Compliance Manager measures; it does not enforce.** It scores and recommends; it does **not** change

the tenant. Acting on an improvement action (a new DLP/label/retention/CA policy) is a **separate**, **piloted-in-simulation** change owned by that feature's solution.

• **Premium content is licensing-gated.** The **Data Protection Baseline** is included, but the

HIPAA/HITECH and **HITRUST CSF** premium templates require **Microsoft 365 E5 / E5 Compliance** or the **Compliance Manager Premium Assessment Add-On**, and the **number** of premium assessments depends on your entitlement. **Verify — do not assume a template is available.** GCC/GCC High and sovereign clouds may differ.

• **Portal-driven.** Assessments, improvement actions, evidence upload, and the authoritative score are

managed in the **Purview portal**. Compliance Manager does **not** expose a broad public PowerShell/Graph API to create assessments or set action status; the provided scripts assess **readiness, roles, and the technical evidence** behind the safeguards and structure the plan/evidence artifacts — they do **not** replace the portal.

• **Automatic testing is partial.** Only **eligible** actions auto-test from Microsoft 365 signals; others

need manual implementation/test and uploaded evidence. Availability is plan/action-dependent — verify.

• **Applicability, addressable-spec choices, risk-analysis outcomes, and adequacy are not technical.**

They are **compliance/privacy/legal** determinations, not outputs of this tool. Records-retention schedules and legal holds are likewise deferred.

• **No secrets in automation.** The scripts use interactive modern-auth sign-in; they never embed

credentials.

Naming convention (used in every doc and script)

Every artifact is named `<Purpose> – <Scope> – <Stage>` and reused verbatim across docs, scripts, and the portal. The standard set:

Artifact	Name
HIPAA assessment (pilot)	`HIPAA Assessment – HITECH – Pilot`
HIPAA assessment (production)	`HIPAA Assessment – Security Rule – Production`
HITRUST assessment (where entitled)	`HIPAA Assessment – HITRUST CSF – Production`
Safeguard → control map	`HIPAA Control Map – Safeguards`
Improvement-action plan (pilot)	`HIPAA Action Plan – Pilot`
Evidence register	`HIPAA Evidence – Register`
Automatic-testing setting	`HIPAA Automatic Testing – Setting`
Score / posture report	`HIPAA Posture – Report`

Artifact	Name
Role-separation evidence snapshot	`HIPAA Roles – Separation Evidence`
Scope / owners record	`HIPAA Scope – Record`

The standard deployment model

> *Baseline the posture → design the assessment, scope, and safeguard map with compliance/privacy/legal → configure roles (separation), create the pilot assessment, build the action plan and evidence register, enable automatic testing → validate the technical evidence behind each safeguard (piloting any new high-impact control in simulation/test) → report the posture → expand to the full program and run the maintenance cadence. Pattern:* ***Assess*** *→* ***Design*** *→* ***Configure*** *→* ***Pilot (simulate/test)*** *→* ***Validate*** *→* ***Expand*** *— HIPAA applicability, addressable-spec choices, risk-analysis outcomes, and evidence adequacy deferred to compliance/privacy/legal at every step.*

2. Requirements Guide — Microsoft Purview HIPAA Compliance Program

Verify **every** requirement before configuring. Each entry: **Description · Why · Verify · Implement-if-missing.** Category-wide prerequisites (tenant/compliance licensing, Purview roles, the PowerShell/Graph toolchain, in-scope data sources, compliance/privacy/legal stakeholders, and a pilot scope with change control) are in `global-requirements-purview.md` — this guide adds the **HIPAA-program-specific** detail. **Licensing, template availability, and portal paths are plan-dependent and the portal evolves — verify each against your own licensing and tenant.**

2.1 Licensing — Compliance Manager premium templates (HIPAA/HITECH, HITRUST CSF)

Description: Compliance Manager and the **Data Protection Baseline** assessment are available to all Microsoft 365 / Office 365 commercial subscriptions, but the **HIPAA/HITECH** premium template — and the **HITRUST CSF** template where you scope it — require **Microsoft 365 E5 / E5 Compliance** or the **Compliance Manager Premium Assessment Add-On**; the **number** of premium assessments you can create is a function of your licensing / seat entitlement. The Purview technical controls the safeguards map to (advanced/auto DLP, auto-labeling, Audit Premium, Insider Risk, Communication Compliance) are themselves largely **E5 / E5 Compliance** capabilities. **Why:** The baseline is free but the HIPAA and HITRUST templates and the advanced controls that evidence several safeguards are entitlement-gated — the most common blocker to standing up the program. **Verify:** Microsoft 365 admin center → `Billing` → `Licenses` for the E5 / E5 Compliance / add-on entitlement; in the Purview portal → **Compliance Manager** → **Assessment templates**, confirm **HIPAA/HITECH** (and HITRUST CSF where needed) show as **available to create**. `CMPHIPAA-Discovery.ps1` reports the licensing SKUs it can read via Graph. **Confirm exact entitlement with Microsoft licensing — do not assume.** GCC/GCC High and sovereign clouds may differ. **Implement:** Assign/purchase the required E5 / E5 Compliance / Premium Assessment Add-On before relying on the HIPAA/HITECH or HITRUST template or the advanced controls.

2.2 Compliance Manager role groups populated with least-privilege separation

Description: The Compliance-Manager role groups — **Compliance Manager Administrators**, **Compliance Manager Assessors**, **Compliance Manager Contributors**, **Compliance Manager Readers** — populated so administrators are separated from safeguard/action **contributors** and from read-only **readers/auditors** (the HIPAA **Security Officer** / **Privacy Officer** typically sit as readers/oversight). Global Administrator, Compliance Administrator, and Compliance Data Administrator also grant access. **Why:** Least-privilege separation is the auditable access control for a HIPAA program: the evidence you produce is only defensible if access to it was itself governed — contributors update actions/evidence without administrator rights, and oversight/auditors get read-only. **Verify:** Purview portal → `Settings → Roles & scopes → Permissions` (or, via `Connect-IPPSSession`, `Get-RoleGroupMember 'Compliance Manager Contributors'` etc.) shows the intended, separated membership. `CMPHIPAA-Discovery.ps1` prints each group's membership as the `HIPAA Roles – Separation Evidence` snapshot and flags an administrator who is also a contributor. **Verify the exact role-group names in your tenant — Purview role naming evolves. Implement:** Assign membership under change control with `CMPHIPAA-Set-Scope.ps1` (`-WhatIf` first, then `-Commit`); grant the **minimum** role each person needs and keep readers/auditors read-only.

2.3 Named HIPAA compliance, privacy, security & legal owners (applicability + adequacy)

Description: Named owners — the **HIPAA Security Officer** and **Privacy Officer** and the **compliance/records/legal** functions — who decide **which safeguards apply**, how each **addressable** specification is satisfied, the outcome of the **risk analysis** (§164.308(a)(1)), which controls are **in/out of scope**, and whether the collected **evidence satisfies** the obligation — plus a **business owner** per in-scope assessment. **Why:** HIPAA applicability, the required-vs-addressable choices, the risk-analysis outcome, and evidence adequacy are **not** technical determinations. The score and evidence are inputs to a compliance decision; the decision belongs to these functions. **Verify:** The applicable safeguards, the addressable-spec decisions, the risk-analysis reference, the scoped/out-of-scope controls, and the named approvers are recorded (`HIPAA Scope – Record`). **Implement:** Engage the Security/Privacy Officers and compliance/legal, capture the safeguard applicability and scope decisions, and assign an owner per assessment before building the action plan.

2.4 In-scope ePHI, workloads, and the safeguard → control map decided

Description: The **workloads and data sources holding ePHI** (Exchange, SharePoint, OneDrive, Teams, endpoints, and any in-scope data estate), the **sensitive-information-type / classification** approach used to *identify* ePHI, and the agreed **HIPAA safeguard** → **Purview control map** (`HIPAA Control Map – Safeguards`) — which Purview capability evidences each safeguard. **Why:** The program's score and evidence key off the in-scope ePHI workloads and the classification scheme; the safeguard map is what turns "we run Purview" into "here is the control that satisfies §164.312(b)." **Verify:** The in-scope ePHI workloads, the SIT/classification approach, and the safeguard→control map are agreed with the owners; each mapped Purview capability shows as available (Requirement 2.1). **Implement:** Confirm the ePHI scope and classification intent, then complete the safeguard→control map before building the assessment and action plan.

2.5 Improvement-action owners and evidence sources identified

Description: For the pilot assessment, the **owner** of each improvement action, its **target date**, its mapped **safeguard**, and where the **evidence** comes from — including which actions are candidates for **automatic testing** (auto-updated from Microsoft 365 signals) versus **manual** evidence upload. **Why:** A HIPAA score with no owners and no evidence is not defensible; ownership and evidence source are what turn recommendations into a trackable, auditor-ready plan (`HIPAA Action Plan – Pilot`, `HIPAA Evidence – Register`). **Verify:** Each pilot action has an owner, a target date, a mapped safeguard, and a named evidence source; automatic-vs-manual actions are identified. **Implement:** Build the action plan with `CMPHIPAA-Configuration.ps1` (`-WhatIf` first) from the owner-provided list; capture the evidence source and mapped safeguard per action.

2.6 Automatic-testing decision and the underlying technical safeguards

Description: A decision on whether to enable **automatic testing** of eligible actions (continuous monitoring reads your Microsoft 365 configuration to update an action's status), and awareness that automatic testing depends on the **underlying technical safeguards** actually being present — e.g. **unified audit logging** (§164.312(b)), **DLP/label/retention** for ePHI, **Conditional Access / MFA** (§164.312(a),(d)). **Why:** Automatic testing keeps technical safeguards current without manual re-checks — but only for **eligible** actions and only when the underlying signal exists. Knowing which is which prevents a false sense of coverage in a compliance record. **Verify:** Purview portal → **Compliance Manager** → **Settings** for the automatic-testing option (`HIPAA Automatic Testing – Setting`); `CMPHIPAA-Validation.ps1` reports the state of the common technical safeguards (audit, DLP, retention, labels, Conditional Access) that back the mapped actions. **Implement:** Enable automatic testing where the owners agree; for actions it can't auto-test, plan manual evidence.

2.7 Security & Compliance PowerShell + Microsoft Graph toolchain

Description: A workstation with the **ExchangeOnlineManagement** module (providing `Connect-IPPSSession` for role-group and evidence cmdlets) and **Microsoft Graph PowerShell** (for licensing and Conditional Access / MFA evidence), used with a modern-auth / MFA-capable admin holding the appropriate Compliance Manager and read roles. **Why:** The five provided scripts assess readiness, roles, and technical evidence through Security & Compliance PowerShell and Graph. Compliance Manager itself is **portal-managed** — the scripts support it, they do not create assessments. **Verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed; `Get-RoleGroup` returns the Compliance Manager groups. `CMPHIPAA-Discovery.ps1` performs these checks. **Implement:** `Install-Module ExchangeOnlineManagement`; `Install-Module Microsoft.Graph`; sign in with the role-holding admin and grant the read scopes the scripts request.

2.8 A pilot assessment and change control

Description: A named **pilot assessment** (`HIPAA Assessment – HITECH – Pilot`) validated first — its action plan, evidence, and automatic-testing behaviour — before the full **production** program is built, plus a **change-control** path for any technical remediation a mapped action triggers (a new DLP, label, retention, or Conditional Access policy — consistent with `global-requirements-purview.md` §6). **Why:** Standing up every safeguard and framework at once produces an unmanageable action backlog; validating one HIPAA assessment end-to-end proves the ownership, evidence, and testing model before

scaling. Technical remediations are high-impact and are piloted in **simulation/test** under change control. **Verify:** A named pilot assessment and its owner exist; a change window / approval path for technical remediation is defined. **Implement:** Choose the HITECH pilot, validate it end-to-end, then expand; agree change control before acting on any high-impact improvement action.

Global Requirements — Microsoft Purview Solutions

These requirements apply to **every** solution in the **Purview** category (implementing and managing Microsoft Purview, sensitivity & retention labels, DLP, data lifecycle & records, insider risk, communication compliance, audit, data security posture management, and data governance). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every Purview solution).*** *The **Microsoft Purview portal** (purview.microsoft.com), the **Microsoft 365 admin center**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** are authored at exact, current click-by-click / cmdlet detail from Microsoft's public documentation. Microsoft Purview features are heavily **licensing-/plan-dependent** (many require **Microsoft 365 E5** or the **E5 Compliance** add-on; some are in preview) and the portal is **actively evolving** — capability availability and portal paths are **cited or flagged "verify your licensing/tenant"**, never asserted or invented. **Regulatory, records-retention, and legal determinations** (retention schedules, records file plans, legal holds, insider-risk case actions, regulatory applicability) are **deferred to the organization's compliance, records, privacy, and legal functions** — the solutions provide the technical configuration method and evidence, not the determination. Automation is **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets.*

1. Microsoft 365 tenant with the required Purview/compliance licensing

• **Description:** A Microsoft 365 tenant with the **compliance licensing** the capability requires (E3 for baseline; **E5 / E5 Compliance** for advanced DLP, auto-labeling, insider risk, communication compliance, Audit Premium, DSPM, etc.).

• **Why required:** Most Purview capabilities are plan-gated; the feature won't be available without the right plan.

• **How to verify:** In the M365 admin center confirm the subscription/add-ons; check the feature is visible in the Purview portal.

• **How to implement if missing:** Assign/purchase the required licensing before starting.

2. Purview roles (least-privilege) and portal access

• **Description:** Access with the least-privilege **Purview / compliance role** the solution names (e.g. Compliance Administrator, Compliance Data Administrator, Information Protection, Records Management, Insider Risk, eDiscovery, Audit roles), with Global Administrator only where required.

• **Why required:** Purview uses fine-grained role groups; configuration requires the matching role.

• **How to verify:** Purview portal → **Roles & scopes / Permissions** — confirm the role membership.

- **How to implement if missing:** Assign the least-privilege role group under change control.

3. Security & Compliance PowerShell + Graph toolchain

- **Description:** A workstation with **Security & Compliance PowerShell** (`Connect-IPPSSession` via the

ExchangeOnlineManagement module) and **Microsoft Graph PowerShell**, modern-auth / MFA-capable admin.

- **Why required:** Configuration, automation, and the provided scripts run through these.
- **How to verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed with the admin account.
- **How to implement if missing:** Install the modules and confirm modern-auth sign-in before running steps.

4. Data sources & scope in scope

- **Description:** The **workloads and data sources** in scope (Exchange, SharePoint, OneDrive, Teams,

endpoints/devices, and — for data governance — the broader data estate) and a **data-classification / sensitivity** intent to drive labels, DLP, and retention.

- **Why required:** Purview policies key off the in-scope workloads and the classification scheme.
- **How to verify:** Confirm the in-scope workloads and the classification/sensitivity approach with

stakeholders.

- **How to implement if missing:** Define the scope and classification intent before authoring policies.

5. Compliance, records, privacy & legal stakeholders

- **Description:** Engagement with the **compliance, records-management, privacy, security, and legal**

stakeholders whose policies the configuration must satisfy (retention schedules, records file plans, regulatory obligations, insider-risk and communication-compliance policy, legal hold).

- **Why required:** Purview configuration must align to enterprise policy and legal/records requirements,

not technical defaults; several capabilities have HR/legal sensitivity.

- **How to verify:** Confirm the applicable policies, the records schedule, and named approvers.
- **How to implement if missing:** Identify the owners and capture the requirements before configuring.

6. A pilot scope and change control

- **Description:** A **pilot scope** (users/sites/policies in simulation or a limited ring) to validate

on before tenant-wide enforcement, and a **change-control** process — most Purview policies support a **simulation / test / disabled** mode that MUST be used before enforcement.

- **Why required:** Every solution follows an **Assess → Design → Configure → Pilot (simulate) → Validate

→ Expand (enforce)** model; DLP, labels, retention, and insider-risk changes are high-impact.

• **How to verify:** Confirm a named pilot scope, that simulation/test mode is available, and a change window/approval path.

• **How to implement if missing:** Define the pilot and agree change control before enforcing anything.

*The deployment model across every Purview solution is the same: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)**, with explicit pass/fail gates and a documented rollback. Automation is delivered as **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets. Regulatory/records/legal determinations are deferred to the relevant governance functions.*

3. Implementation Guide — Microsoft Purview HIPAA Compliance Program

Follow these steps **in order**. Configuration is done in the **Microsoft Purview portal** (`https://purview.microsoft.com` → **Compliance Manager**) and, where automated, via **Security & Compliance PowerShell** (`Connect-IPPSSession`, for role groups and technical evidence) and **Microsoft Graph** (for licensing and Conditional Access / MFA evidence). Artifact names follow the `<Purpose> – <Scope> – <Stage>` convention from the Overview and are reused verbatim. **Portal paths, template availability, and cmdlets are plan-dependent and the portal evolves — verify against your tenant.**

> ***Model:*** *Baseline the posture, design the assessment/scope/safeguard-map, configure roles + assessment + action plan + automatic testing, validate the technical evidence behind each safeguard, report, then expand. Pattern:* ***Assess*** *→* ***Design*** *→* ***Configure*** *→* ***Pilot (simulate/test)*** *→* ***Validate*** *→* ***Expand. Compliance Manager measures — it does not enforce.*** *Any *technical* remediation a mapped action recommends (a new DLP/label/retention/CA policy) is a* ***separate, piloted-in-simulation*** *change owned by that feature's solution; and* ***HIPAA applicability, addressable-spec choices, risk-analysis outcomes, and evidence adequacy are compliance/privacy/legal determinations****, not decisions this guide makes.*

Step 1 — Baseline the posture and capture role/licensing readiness (Assess)

1. Confirm licensing (Requirement 2.1): portal → **Compliance Manager** → **Assessment templates** — the

HIPAA/HITECH template (and **HITRUST CSF** where scoped) show as available. **Verify entitlement with Microsoft licensing — do not assume.**

1. Run `CMPHIPAA-Discovery.ps1` (read-only). It reports the licensing SKUs it can read, the membership of

each Compliance Manager role group (the `HIPAA Roles – Separation Evidence` snapshot), flags any administrator who is also a contributor, and captures the current state of the common technical safeguards (unified audit ingestion, DLP/retention/label presence). Note the current **Compliance Score**

from the portal dashboard as the starting point.

1. **Pass/fail gate:** licensing confirmed for the HIPAA (and any HITRUST) template, the Compliance

Manager role groups exist, and you have the baseline recorded. **Do not proceed** until the HIPAA Security/Privacy Officers and compliance/legal (Requirement 2.3) have confirmed which safeguards apply and are in scope. Fail → resolve before configuring.

Step 2 — Assign roles with least-privilege separation (Configure — guardrails)

1. Portal → `Settings → Roles & scopes → Permissions`: populate the Compliance Manager role groups

(Requirement 2.2):

- **Compliance Manager Administrators** → the program owners / IT config staff.
- **Compliance Manager Assessors** → assessment leads who create assessments and set **test** status.
- **Compliance Manager Contributors** → the safeguard/action **owners** who update actions/evidence.
- **Compliance Manager Readers** → oversight/auditors and the HIPAA **Security/Privacy Officer**,

read-only.

1. Or manage membership with `CMPHIPAA-Set-Scope.ps1` — it composes `Add-RoleGroupMember` /

`Remove-RoleGroupMember`. **It runs with** `-WhatIf` **by default** and prints exactly what it would change; add `-Commit` to apply. Grant the **minimum** role each person needs.

1. **Pass/fail gate:** each person holds the least-privilege role; administrators are separated from

contributors; the Security/Privacy Officer and auditors are read-only. Re-run `CMPHIPAA-Discovery.ps1` and confirm the `HIPAA Roles – Separation Evidence` snapshot. **Rollback:** remove any over-granted membership with `CMPHIPAA-Set-Scope.ps1 -Commit`.

Step 3 — Design the assessment, scope, and safeguard map (Design)

1. With the HIPAA owners, confirm the **in-scope assessment template(s)** (Requirement 2.4): **HIPAA/HITECH**

plus **HITRUST CSF** where entitled and required. **Applicability is the owners' determination.**

1. Confirm the **in-scope ePHI workloads** and the **classification / sensitive-information-type** approach

used to *identify* ePHI, and complete the **safeguard** → **Purview control map** — which capability (Audit, labels, DLP, retention, Conditional Access, etc.) evidences each safeguard. Record it as `HIPAA Control Map – Safeguards`.

1. Decide the **grouping** (HIPAA program group; HITRUST/NIST alongside for shared-control leverage), and

assign a **business owner** per assessment.

1. Record the design as `HIPAA Scope – Record` (templates, ePHI scope, grouping, owners, in-/out-of-scope

safeguards, addressable-spec decisions, risk-analysis reference). Use `CMPHIPAA-Configuration.ps1` (`-WhatIf` first) to scaffold the control-map and scope artifacts from the owner-provided inputs.

Step 4 — Create the pilot assessment (Configure — pilot-first)

1. Portal → **Compliance Manager** → **Assessments** → **Add assessment**: create `HIPAA Assessment – HITECH –

Pilot` from the **HIPAA/HITECH** template, in the agreed group. (Premium/HITRUST templates require the entitlement from Requirement 2.1.)

1. **Keep the pilot to one assessment.** Validating the HITECH assessment end-to-end — safeguard mapping,

ownership, evidence, automatic testing — proves the model before you build the full program. Compliance Manager does not change your tenant, so creating the assessment is safe; the *work* it surfaces is what you pilot.

1. **Pass/fail gate:** the pilot assessment exists in the correct group with an owner, and its improvement

actions and current score are visible. Fail → check template availability/licensing. **Rollback:** an assessment can be removed in the portal without affecting tenant configuration.

Step 5 — Build the improvement-action plan and evidence register (Configure)

1. For `HIPAA Assessment – HITECH – Pilot`, assign each **improvement action** an **owner**, a **target

date**, an** implementation status**, and its** mapped safeguard**, in the portal (action** → Assign** / edit).

1. Use `CMPHIPAA-Configuration.ps1` to build the tracking artifacts from the owner-provided list — it

validates the action plan and, with `-Commit`, writes the local `HIPAA Action Plan – Pilot`, `HIPAA Evidence – Register`, and `HIPAA Control Map – Safeguards` files (owner, target date, status, mapped safeguard, evidence source per action). **It runs with** `-WhatIf` **by default** and only *describes* the plan; **it makes no tenant changes** — Compliance Manager has no write API, so assignments and evidence upload happen in the portal, driven by these artifacts.

1. Attach **evidence** to each action in the portal (audit configuration exports, DLP/label/retention

policy proof, Conditional Access reports) and record its source in the register.

1. **Pass/fail gate:** every pilot action has an owner, a target date, a status, a mapped safeguard, and a

named evidence source. Fail → complete the plan before validating.

Step 6 — Enable automatic testing where it applies (Configure)

1. Portal → **Compliance Manager** → **Settings**: set the **automatic testing** option (`HIPAA Automatic

Testing – Setting`) per the owners' decision (Requirement 2.6). Eligible actions will update their **test status** from your Microsoft 365 configuration signals.

1. Run `CMPHIPAA-Validation.ps1` (read-only) to confirm the **underlying technical safeguards** the

automatable actions depend on are present — **unified audit logging enabled**, **DLP / retention / sensitivity-label** policies for ePHI present, **Conditional Access / MFA** configured. This tells you which safeguards can auto-pass and which still need **manual** evidence.

1. **Pass/fail gate:** automatic testing is set as agreed, and you know which safeguards are auto-tested vs

manual-evidence. Fail → enable automatic testing or record the manual-evidence actions.

Step 7 — Validate the evidence behind each safeguard (Pilot → Validate)

1. Run the Testing Guide (`05-testing.md`). Confirm: the pilot assessment shows a score; each action's

implementation and **test** status is set with **evidence**; automatic-tested actions reflect the real technical state (cross-checked by `CMPHIPAA-Validation.ps1`); the safeguard map is complete; role separation holds.

1. Where a mapped action recommends a **new technical control** (enable audit, add a DLP for ePHI, deploy

a sensitivity label with encryption, add retention, tighten Conditional Access), **pilot that change in simulation/test first** under its own change control — those high-impact changes are owned by their feature's solution, not switched on blind here. Re-run `CMPHIPAA-Validation.ps1` to capture the new evidence.

1. Run `CMPHIPAA-Report.ps1` for the `HIPAA Posture – Report` (score, safeguard-status rollup, evidence

register, role separation, licensing).

1. **Pass/fail gate:** the pilot assessment is fully owned, mapped, evidenced, and tested; automatic

testing reflects reality; the posture report is accurate. Fail → complete evidence/testing and re-validate.

Step 8 — Expand to the full HIPAA program and run the cadence (Expand)

1. With the HIPAA owners, create the remaining production assessment(s) — `HIPAA Assessment – Security

Rule – Production `and, where entitled,` HIPAA Assessment – HITRUST CSF – Production` — from their licensed templates, in the agreed grouping. **Lean on control mapping:** controls already implemented for the HITECH pilot often satisfy the same safeguard in HITRUST/NIST automatically (shared controls), so the incremental effort is the *gap*.

1. Extend the **action plan**, **evidence register**, and **safeguard map** to the new assessments

(owners, dates, evidence) with `CMPHIPAA-Configuration.ps1`.

1. Stand up the **maintenance cadence**: periodic re-test/re-evidence of safeguards, review of owners

(joiners/leavers, Security/Privacy Officer changes), watch for **template/regulation updates** Microsoft publishes, and re-run `CMPHIPAA-Report.ps1` on a schedule for the posture trend and the annual **evaluation** (§164.308(a)(8)).

1. **Pass/fail gate:** the full in-scope program exists, is owned, mapped, and evidenced, automatic

testing is running, and a recurring review is scheduled. **Rollback:** any assessment can be removed in the portal without touching tenant configuration; scope can be narrowed at any time.

What this guide does NOT decide

• **Which HIPAA safeguards apply, how each addressable specification is satisfied, the risk-analysis

outcome, and whether the evidence satisfies the obligation — compliance/privacy/legal determinations**. This guide configures the assessment, the safeguard map, the action plan, and the evidence, and produces the score and posture; adequacy and sign-off belong to those functions.

• **The high-impact technical controls a mapped action recommends** — enabling audit, DLP for ePHI,

labels/encryption, retention, Conditional Access — are **separate, piloted-in-simulation** changes owned by their own solution; Compliance Manager only measures whether they are in place.

• **Records-retention schedules, legal holds, and breach-notification decisions** — deferred to

records/privacy/legal; this program provides the technical preservation method and the evidence.

5. Testing Guide — Microsoft Purview HIPAA Compliance Program

Run these after assigning roles (Step 2) and building the pilot assessment, action plan, and automatic testing (Steps 4–6), and again after each change and before expanding. Every test here is **safe and read-only** or contained to the **pilot assessment** — Compliance Manager itself changes nothing on the tenant; the point is to prove the **score, safeguard mapping, ownership, evidence, automatic testing, and role separation** all work before you build the full HIPAA program. **Adequacy, applicability, and the risk-analysis outcome remain compliance/privacy/legal determinations — these tests validate the mechanism.**

Test 1 — Role separation is in place (the access guardrail)

Do: Run `CMPHIPAA-Discovery.ps1`; review the `HIPAA Roles – Separation Evidence` snapshot of each Compliance Manager role group's membership. **Expected:** Administrators are separated from contributors; assessors set test status; the HIPAA Security/Privacy Officer and auditors are **read-only**. No administrator is silently also a contributor unless the owners accepted it. **Fail** → correct membership with `CMPHIPAA-Set-Scope.ps1` (Implementation Step 2) before proceeding.

Test 2 — Licensing supports the HIPAA (and HITRUST) template

Do: Run `CMPHIPAA-Discovery.ps1` and, in the portal → **Compliance Manager** → **Assessment templates**, confirm the **HIPAA/HITECH** template (and **HITRUST CSF** where scoped) is available to

create. **Expected:** The HIPAA/HITECH template shows as available under your entitlement; HITRUST CSF likewise where scoped. **Fail** → resolve licensing (Requirement 2.1) before creating that assessment.

Test 3 — The pilot assessment exists and is scored

Do: In the portal → **Compliance Manager** → **Assessments**, open `HIPAA Assessment – HITECH – Pilot`. **Expected:** The assessment is in the agreed group, has an owner, and shows a **Compliance Score** and its improvement actions grouped by safeguard. **Fail** → recreate/repair the assessment (Implementation Step 4).

Test 4 — Every pilot action has an owner, target date, status, mapped safeguard, and evidence source

Do: Run `CMPHIPAA-Report.ps1`; review the `HIPAA Action Plan – Pilot` / `HIPAA Evidence – Register` / `HIPAA Control Map – Safeguards` rollup against the assessment's actions in the portal. **Expected:** Each improvement action has an **owner**, a **target date**, an **implementation status**, a **mapped HIPAA safeguard**, and a **named evidence source**; nothing is unassigned or unmapped. **Fail** → complete the plan with `CMPHIPAA-Configuration.ps1` and assign in the portal.

Test 5 — Automatic testing reflects the real technical safeguard state (true evidence)

Do: Confirm automatic testing is enabled (`HIPAA Automatic Testing – Setting`), then run `CMPHIPAA-Validation.ps1` (read-only) and compare its findings to the auto-tested actions' status. **Expected:** For a safeguard Compliance Manager auto-tests (e.g. **§164.312(b) audit controls** → unified audit logging enabled), the tool's finding matches the action's **test status** — the score reflects reality, not a stale value. **Fail** → confirm auto-testing eligibility and the underlying signal; some safeguards need manual evidence.

Test 6 — A not-yet-implemented safeguard scores as such (no false pass)

Do: Pick a mapped action whose technical control is **not** in place (e.g. no DLP for ePHI yet); check its status in the portal and cross-check with `CMPHIPAA-Validation.ps1`. **Expected:** The action shows **Not implemented / not tested** (or Failed), and the tool confirms the control is absent — the HIPAA score is **not** inflated. **Fail** → correct the status/evidence; do not mark a safeguard implemented without proof.

Test 7 — Manual evidence is attached and defensible

Do: Open two or three manually-evidenced actions in the portal (e.g. a documentation/§164.316 or workforce-training §164.308(a)(5) action); confirm the uploaded **evidence**, **owner**, and **test date** are present, and that `HIPAA Evidence – Register` records the source. **Expected:** Each manual action carries proof, an owner, and a date — an OCR/BAA-audit-ready record. **Fail** → attach the evidence and record it in the register.

Test 8 — Control mapping / shared controls behave as expected (evidence once, score many)

Do: After the HITECH baseline actions are implemented, create a second assessment from a licensed template (a pilot of HITRUST CSF or NIST) and inspect the shared/mapped controls. **Expected:** Controls already satisfied for HITECH (e.g. audit, MFA) show as **implemented** in the new assessment via **shared/control mapping** — you did not redo the work. **Fail** → verify the action is a shared/Microsoft-managed control and its status is set.

Test 9 — Posture report is accurate and complete

Do: Run `CMPHIPAA-Report.ps1` for the `HIPAA Posture – Report`. **Expected:** The report rolls up the score, the safeguard-status breakdown (Administrative / Physical / Technical), the evidence register, the role-separation snapshot, and the licensing — matching the portal. It notes that the **authoritative score and export** are the portal's Compliance Manager export. **Fail** → confirm inputs and re-run.

Test 10 — Safe automation defaults

Do: Run `CMPHIPAA-Configuration.ps1` and `CMPHIPAA-Set-Scope.ps1` with no action switch. **Expected:** Each runs in `-WhatIf` mode and only *describes* the change; nothing is written until `-Commit` is supplied. `CMPHIPAA-Discovery.ps1`, `CMPHIPAA-Validation.ps1`, and `CMPHIPAA-Report.ps1` are read-only. **Fail** → stop; do not run with `-Commit` until the dry-run output is correct.

Gate to expand: Tests 1–2 (guardrails + licensing), 3–4 (assessment + ownership + mapping), 5–7 (evidence accuracy), 8 (control mapping), and 9–10 (reporting + safety) all pass for the HITECH pilot → proceed to the full program (Implementation Step 8). Any fail → correct and re-test. **Whether the resulting score/evidence satisfies the HIPAA obligation is a compliance/privacy/legal decision, not a technical one.**

6. Troubleshooting — Microsoft Purview HIPAA Compliance Program

Common failure modes and how to resolve them. Ordered roughly by where they surface in the model **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand.** Portal paths, template availability, and cmdlets are **plan-dependent and the portal evolves — verify against your tenant.**

The HIPAA/HITECH (or HITRUST CSF) template is not available to create

- **Cause:** Premium templates require **Microsoft 365 E5 / E5 Compliance** or the **Compliance Manager

Premium Assessment Add-On**, and the** number** of premium assessments is entitlement-bound. GCC/GCC High and sovereign clouds may differ.

- **Fix:** Confirm entitlement in the M365 admin center → `Billing → Licenses`; in the portal →

Compliance Manager → **Assessment templates**, check the template shows as available. `CMPHIPAA-Discovery.ps1` reports the compliance-capable SKUs it can read, but SKU strings vary — **confirm with Microsoft licensing, don't assume**. Assign/purchase the required plan before relying on the template.

`Connect-IPPSSession` or `Connect-MgGraph` fails

- **Cause:** Missing module, no modern-auth/MFA, or insufficient role.
- **Fix:** `Install-Module ExchangeOnlineManagement` and `Install-Module Microsoft.Graph` (`-Scope CurrentUser`). Sign in with a modern-auth / MFA-capable admin holding a Compliance Manager role (or Compliance Administrator). For Graph sections, consent to the read scopes the script requests (`Organization.Read.All`, `Directory.Read.All` for licensing; `Policy.Read.All` for Conditional Access). Use `-SkipGraphLicensing` / `-SkipGraphCA` to run the non-Graph sections if Graph is unavailable.

A role group "could not be read" or a name looks wrong

- **Cause:** Purview role-group naming evolves; the exact Compliance Manager role-group names in your tenant may differ from the defaults, or your admin lacks rights to read membership.
- **Fix:** In the portal → `Settings → Roles & scopes → Permissions`, confirm the actual role-group names, then re-run with those names. `Get-RoleGroup` (via `Connect-IPPSSession`) lists what exists. Ensure the running admin can read role-group membership.

Separation-of-duties flag: someone is Administrator AND Contributor

- **Cause:** A person holds both the config-owning **Administrators** role and the action-owning **Contributors** role — the evidence you produce is less defensible if access to it was not separated.
- **Fix:** Decide with the HIPAA owners whether the overlap is accepted; if not, remove the surplus membership with `CMPHIPAA-Set-Scope.ps1 -Action Remove ... -Commit`. Keep the Security/Privacy Officer and auditors as **Readers**.

The score didn't change after I "implemented" a safeguard

- **Cause:** Compliance Manager **measures; it does not enforce.** Marking an action implemented in the portal does not change the tenant — and if automatic testing is on, the action's **test status** reflects the *actual* technical signal, which may still be absent.
- **Fix:** Run `CMPHIPAA-Validation.ps1` to confirm the underlying control (audit ingestion, DLP for ePHI, label, retention, Conditional Access) is actually present. If it is absent, the safeguard is genuinely not implemented — deploy that control in **its own solution**, piloted in simulation/test first, then re-validate. Do not mark a safeguard implemented without proof (no false passes).

A safeguard shows implemented but `CMPHIPAA-Validation.ps1` says the control is ABSENT

• **Cause:** A manual "Implemented" status was set without the technical control being in place — a false pass that inflates the HIPAA score (worse than a low score in an OCR investigation).

• **Fix:** Reset the action to **Not implemented / Not assessed** until the control exists and is evidenced. Attach real evidence (audit-config export, policy screenshot/export, CA report) and set the test status/date. Prefer **automatic testing** for the technical safeguards it can read.

Automatic testing isn't updating an action

• **Cause:** Not every improvement action is **eligible** for automatic testing; eligibility is plan/action-dependent, and the underlying Microsoft 365 signal must exist.

• **Fix:** Confirm automatic testing is enabled (`HIPAA Automatic Testing – Setting`) in **Compliance Manager → Settings**. **For ineligible actions (most Administrative/Physical safeguards — training, BAAs, facility controls, policy documents), attach** manual** evidence with an owner and date; record the source in `HIPAA Evidence – Register`.

`CMPHIPAA-Configuration.ps1` reports rows as FAIL

• **Cause:** A row is missing a mandatory field (Action, Safeguard, Owner, TargetDate, ImplementationStatus, EvidenceSource, TestMode) or the TargetDate doesn't parse.

• **Fix:** Complete the owner-provided CSV — every action needs an owner, a valid target date, a mapped safeguard, and a named evidence source. Re-run the dry-run until all rows are OK, then `-Commit`.

I expected the scripts to create the assessment / set action status — they didn't

• **Cause:** Compliance Manager does **not** expose a broad public PowerShell/Graph write API to create assessments or set action/evidence status. The scripts assess readiness/roles and the **technical evidence** and structure the local plan/evidence artifacts.

• **Fix:** Create the assessment, assign actions, and upload evidence in the **Purview portal**, driven by the `HIPAA Action Plan – Pilot` / `HIPAA Evidence – Register` / `HIPAA Control Map – Safeguards` artifacts the Configuration script writes.

Shared controls didn't credit across HITECH and HITRUST/NIST

• **Cause:** The action is not a shared/Microsoft-managed control, or its status wasn't set on the source assessment.

• **Fix:** Confirm the control is a **shared** control and its implementation/test status is set; shared controls credit automatically across assessments that map the same control. Track only the **gap** between frameworks, not the overlap.

A high-impact technical remediation caused disruption

• **Cause:** A mapped action's technical control (a new DLP, label with encryption, retention, or

Conditional Access policy) was enforced without piloting.

• **Fix:** Always deploy high-impact controls in **simulation/test/disabled** mode first, under their own

change control, in their own solution — then evidence them here. Roll the control back in its own feature; **removing the Compliance Manager assessment does not undo a tenant change** (the assessment only measures).

Rollback

• **Assessments/measurement:** any assessment can be removed in the portal without touching tenant

configuration; scope can be narrowed at any time (non-destructive).

• **Roles:** revert membership with `CMPHIPAA-Set-Scope.ps1 -Action Remove ... -Commit`.

• **Technical controls:** roll back in the owning feature's solution — not here; this program only measures

and evidences.

*Whether the resulting score/evidence satisfies the HIPAA obligation — and which safeguards apply, how each addressable specification is met, and the risk-analysis outcome — are **compliance/privacy/legal determinations**, not technical fixes in this guide.*

7. Best Practices — Microsoft Purview HIPAA Compliance Program

Operating principles for running a defensible, low-drama HIPAA program in Microsoft Purview. They extend `global-requirements-purview.md` and the model **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand**.

Program & governance

• **The program measures; the determinations stay with your officers.** Compliance Manager scores and

evidences; **applicability, required-vs-addressable choices, the risk-analysis outcome, and evidence adequacy** stay with the HIPAA **Security Officer**, **Privacy Officer**, and compliance/legal. Keep that boundary explicit in every artifact so a technical status is never mistaken for a compliance ruling.

• **Anchor to the risk analysis (§164.308(a)(1)).** The Security Rule requires a risk analysis; the

Purview control map should trace back to it. Record the risk-analysis reference in `HIPAA Scope -Record` so each safeguard's presence is justified, not arbitrary.

• **Name the safeguard on every action.** Every improvement action carries its **mapped HIPAA safeguard**

(§164.308/310/312/314/316) so the score reads as a HIPAA statement, not a generic checklist.

- **Evidence once, score many.** Lean on **shared/control mapping** — implement audit, MFA, DLP, labels,

and retention once and let Compliance Manager credit them across HITECH, HITRUST, NIST, and your internal baseline. Track the *gap* between frameworks, not the overlap.

Configuration discipline

- **Least-privilege, separated roles — always.** Administrators separated from contributors; the

Security/Privacy Officer and auditors **read-only**. The evidence is only defensible if access to it was governed. Re-check with `CMPHIPAA-Discovery.ps1` after any joiner/leaver.

- **Pilot one assessment before the program.** Validate `HIPAA Assessment – HITECH – Pilot` end-to-end —

mapping, ownership, evidence, automatic testing — before creating the production assessments. It proves the model and prevents an unmanageable action backlog.

- **Pilot every high-impact technical control in simulation/test first.** When a mapped action needs a

new DLP for ePHI, a label with encryption, a retention policy, or tighter Conditional Access, deploy it in **simulation/test/disabled** mode under its own change control before enforcement — then evidence it here. Never switch on a high-impact control blind because the score wants a point.

- **Safe automation defaults.** The write-capable scripts default to `-WhatIf`; read the dry-run

before `-Commit`. Never embed credentials — the scripts use interactive modern-auth sign-in.

Evidence & audit-readiness

- **Automatic testing where eligible, manual evidence everywhere else — and know which is which.** Enable

automatic testing for the technical safeguards it can read; for administrative/physical safeguards (training, BAAs, facility controls, policies) attach **manual** evidence with an owner and a date. A mixed record with a clear split prevents a false sense of coverage.

- **No false passes.** An action is **Implemented/Passed** only with proof. If `CMPHIPAA-Validation.ps1`

shows the underlying control is absent, the safeguard scores as not-implemented — an inflated HIPAA score is worse than a low one in an OCR investigation.

- **The portal is authoritative; the scripts support it.** The score, assessments, and evidence store

live in the **Purview portal**. Treat `HIPAA Posture – Report` as a management rollup, and export the authoritative record from Compliance Manager for auditors.

- **Keep the evidence current.** Re-test and re-evidence on a cadence; a year-old audit-config export is

weak evidence. Schedule `CMPHIPAA-Report.ps1` and drive the annual **evaluation** (§164.308(a)(8)).

HR/privacy-sensitive controls (Insider Risk & Communication Compliance)

• **Privacy-by-design, strict role separation, outcomes deferred.** Where the program maps a

security-incident/monitoring safeguard to **Insider Risk Management** or **Communication Compliance**, configure them **privacy-first** (pseudonymization where available), separate the reviewer role, and defer all **case actions/outcomes** to HR/legal. This program evidences that the *capability* exists — never a case decision.

Lifecycle & maintenance

• **Watch template and regulation updates.** Microsoft updates Compliance Manager templates; HIPAA/HITRUST

guidance evolves. Review updates on a cadence and re-map affected safeguards.

• **Review owners on joiners/leavers.** Reassign action ownership and re-check role separation whenever

the Security/Privacy Officer or an action owner changes.

• **Narrow scope safely.** Any assessment can be removed in the portal without touching tenant

configuration; scope can be narrowed at any time. Nothing in this program enforces on the tenant, so rolling back the *measurement* is non-destructive — but do not remove the underlying technical controls that other frameworks also rely on.

8. Deliverables Summary — Microsoft Purview HIPAA Compliance Program

What you receive, what it produces, and what stays a governance determination.

Documents

Document	What it gives you
01 · Solution Overview	What the HIPAA program is in Purview, the safeguard → control map, the role-separation model, limitations, the naming convention, and the Assess→Design→Configure→Pilot→Validate→Expand model.
02 · Requirements Guide	Every HIPAA-program prerequisite — licensing (HIPAA/HITECH + HITRUST templates), separated Compliance Manager roles, named HIPAA owners, in-scope ePHI + safeguard map, action owners/evidence, automatic-testing decision, toolchain, pilot + change control — each with Verify / Implement-if-missing, referencing the category global requirements.

Document	What it gives you
03 · Implementation Guide	The exact ordered steps: baseline → roles → design the assessment/scope/safeguard-map → create the HITECH pilot → build the action plan + evidence register → enable automatic testing → validate the technical evidence → expand — every artifact named, each step with a pass/fail gate and rollback.
05 · Testing Guide	Ten safe/read-only or pilot-scoped tests validating role separation, licensing, the assessment/score, ownership + mapping + evidence, automatic-testing accuracy, no-false-pass, shared-control mapping, the posture report, and safe automation defaults — with a gate to expand.
06 · Troubleshooting	The common failure modes (template not available, role/permission gaps, connection issues, false pass/fail, no write API expectations) and how to resolve them.
07 · Best Practices	Operating principles — governance boundary, risk-analysis anchor, evidence-once-score-many, least-privilege, pilot-first, evidence/audit-readiness, HR/privacy-sensitive controls, and lifecycle maintenance.
Executive Summary	The one-page business case: outcome, model, and the governance boundary — for the sponsor and the HIPAA officers.

PowerShell tools (5) — Security & Compliance PowerShell / Microsoft Graph

All safe-by-default (read-only, or `-WhatIf` until `-Commit`); **no credentials in code** — interactive modern-auth sign-in. Compliance Manager is **portal-managed**; these scripts assess readiness/roles and the **technical evidence** behind the safeguards and structure the plan/evidence artifacts — they do not create assessments.

Script	Purpose	Default
CMPHIPAA-Discovery.ps1	Reports licensing SKUs (HIPAA/HITECH + advanced-control entitlement), Compliance Manager role-group membership (`HIPAA Roles – Separation Evidence`, flags admin-also-contributor), and the current state of the common technical safeguards (audit, DLP, retention, labels).	Read-only

Script	Purpose	Default
CMPHIPAA-Configuration.ps1	Builds/validates the local tracking artifacts — `HIPAA Action Plan – Pilot`, `HIPAA Evidence – Register`, `HIPAA Control Map – Safeguards`, `HIPAA Scope – Record` — from the owner-provided action list (owner, target date, status, mapped safeguard, evidence source). Makes **no tenant changes**.	`-WhatIf` (write local files with `-Commit`)
CMPHIPAA-Validation.ps1	Read-only check of the **underlying technical safeguards** behind the mapped actions — unified audit ingestion (§164.312(b)), DLP/retention/sensitivity-label presence for ePHI, Conditional Access / MFA (§164.312(a),(d)) — so you know which auto-test and which need manual evidence.	Read-only
CMPHIPAA-Report.ps1	Produces the `HIPAA Posture – Report` — score context, safeguard-status rollup (Administrative/Physical/Technical), evidence register, role separation, licensing — a management rollup alongside the portal's authoritative export.	Read-only
CMPHIPAA-Set-Scope.ps1	Scope/health helper — manages Compliance Manager role-group membership (`Add-/Remove-RoleGroupMember`) for least-privilege separation.	`-WhatIf` (apply with `-Commit`)

Named artifacts this program creates/tracks

`HIPAA Assessment – HITECH – Pilot` · `HIPAA Assessment – Security Rule – Production` · `HIPAA Assessment – HITRUST CSF – Production` · `HIPAA Control Map – Safeguards` · `HIPAA Action Plan – Pilot` · `HIPAA Evidence – Register` · `HIPAA Automatic Testing – Setting` · `HIPAA Posture – Report` · `HIPAA Roles – Separation Evidence` · `HIPAA Scope – Record`.

Outcomes

- A **scored, control-by-control HIPAA program** in Compliance Manager (HIPAA/HITECH, and HITRUST CSF

where entitled), with a safeguard → Purview control map.

- An **auditor-ready evidence register** — owners, implementation status, test status/date, and proof per

safeguard — with automatic testing where eligible.

- **Least-privilege role separation** proven and snapshotted.
- A **posture report** and a **maintenance cadence** (re-test, re-evidence, review owners, annual

evaluation), leaning on shared controls to expand efficiently.

Explicitly out of scope (governance determinations, not technical outputs)

- **Which HIPAA safeguards apply, how each addressable specification is met, the risk-analysis outcome,

and whether the evidence satisfies the obligation** — compliance/privacy/legal.

- **The high-impact technical controls a mapped action recommends** (new DLP/label/retention/CA policy) —

separate, piloted-in-simulation changes owned by their own solution.

- **Records-retention schedules, legal holds, and breach-notification decisions** — records/privacy/legal.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

CMPHIPAA-Configuration.ps1

Purpose: Structures the program's tracking artifacts from an owner-provided action list: validates each row (action, mapped HIPAA safeguard, owner, target date, implementation status, evidence source, auto-vs-manual) and, with -Commit, writes the local HIPAA Action Plan - Pilot, HIPAA Evidence - Register, HIPAA Control Map - Safeguards, and HIPAA Scope - Record CSV files. Compliance Manager has no public write API, so assessment/action assignment and evidence upload happen in the Purview portal — driven by these artifacts. This script makes NO tenant changes. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\CMPHIPAA-Configuration.ps1 -InputCsv .\actions.csv (dry-run; validate + preview). Add -Commit to write the artifact files: powershell -ExecutionPolicy Bypass -File .\CMPHIPAA-Configuration.ps1 -InputCsv .\actions.csv -Commit PowerShell 5.1+ / 7+. No connection or credentials required — operates on local CSV only. EXPECTED RESULTS Dry-run prints validation results and the artifacts it WOULD write. With -Commit, four CSV files are written to -OutDir. Any row missing an owner, target date, mapped safeguard, or evidence source is reported as a FAIL and (in -Commit) excluded until fixed. .NOTES Purview category — HIPAA compliance program. Local-only artifact builder; makes no tenant changes and embeds no credentials. Applicability/adequacy and the addressable-spec choices remain compliance/privacy/legal determinations — this only structures the evidence. > [CmdletBinding()] param([string]$InputCsv, # owner-provided action list (see expected columns below) [string]$OutDir = (Join-Path (Get-Location) 'HIPAA-artifacts'), [switch]$Commit # write files; without it, dry-run only)

How to run: powershell -ExecutionPolicy Bypass -File .\CMPHIPAA-Configuration.ps1 -InputCsv .\actions.csv (dry-run; validate + preview). Add -Commit to write the artifact files: powershell -ExecutionPolicy Bypass -File .\CMPHIPAA-Configuration.ps1 -InputCsv .\actions.csv -Commit PowerShell 5.1+ / 7+. No connection or credentials required — operates on local CSV only. EXPECTED RESULTS Dry-run prints validation results and the artifacts it WOULD write. With -Commit, four CSV files are written to -OutDir. Any row missing an owner, target date, mapped safeguard, or evidence source is reported as a FAIL and (in -Commit) excluded until fixed. .NOTES Purview category — HIPAA compliance program. Local-only artifact builder; makes no tenant changes and embeds no credentials. Applicability/adequacy and the addressable-spec choices remain compliance/privacy/legal determinations — this only structures the evidence. > [CmdletBinding()] param([string]$InputCsv, # owner-provided action list (see expected columns below) [string]$OutDir = (Join-Path (Get-Location) 'HIPAA-artifacts'), [switch]$Commit # write files; without it, dry-run only)

CMPHIPAA-Discovery.ps1

Purpose: Reports HIPAA-program readiness with no changes: the licensing SKUs it can read (E5 / E5 Compliance entitlement that gates the HIPAA/HITECH + HITRUST templates and the advanced controls), the membership of each Compliance Manager role group (the HIPAA Roles - Separation Evidence snapshot, flagging any administrator who is also a contributor), and the current state of the common technical safeguards (unified audit ingestion, DLP / retention / sensitivity-label presence). Read-only. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\CMPHIPAA-Discovery.ps1 PowerShell 5.1+ / 7+. Requires ExchangeOnlineManagement (Connect-IPPSSession) and, for the licensing section, Microsoft.Graph with delegated Organization.Read.All / Directory.Read.All. Interactive modern-auth / MFA

admin sign-in; no secrets in code. EXPECTED RESULTS A readiness summary: E5/E5-Compliance plan present Yes/No with an assigned-user count; each Compliance Manager role group's membership with admin-also-contributor flagged; and a technical baseline (audit ingestion on/off, count of DLP / retention / label policies). Any "verify your licensing/tenant" item is flagged, not asserted. .NOTES Purview category — HIPAA compliance program. Read-only. Compliance Manager is portal-managed; this script does not create assessments. Feature/template availability is licensing-/tenant-dependent and evolving — confirm against your entitlements and current Microsoft documentation. > [CmdletBinding()] param([string]$UserPrincipalName, # optional: admin UPN to pass to Connect-* prompts [switch]$SkipGraphLicensing # skip the Graph licensing section if Graph is unavailable)

How to run: powershell -ExecutionPolicy Bypass -File .\CMPHIPAA-Discovery.ps1 PowerShell 5.1+ / 7+. Requires ExchangeOnlineManagement (Connect-IPPSSession) and, for the licensing section, Microsoft.Graph with delegated Organization.Read.All / Directory.Read.All. Interactive modern-auth / MFA admin sign-in; no secrets in code. EXPECTED RESULTS A readiness summary: E5/E5-Compliance plan present Yes/No with an assigned-user count; each Compliance Manager role group's membership with admin-also-contributor flagged; and a technical baseline (audit ingestion on/off, count of DLP / retention / label policies). Any "verify your licensing/tenant" item is flagged, not asserted. .NOTES Purview category — HIPAA compliance program. Read-only. Compliance Manager is portal-managed; this script does not create assessments. Feature/template availability is licensing-/tenant-dependent and evolving — confirm against your entitlements and current Microsoft documentation. > [CmdletBinding()] param([string]$UserPrincipalName, # optional: admin UPN to pass to Connect-* prompts [switch]$SkipGraphLicensing # skip the Graph licensing section if Graph is unavailable)

CMPHIPAA-Report.ps1

Purpose: Assembles a HIPAA Posture - Report from the local tracking artifacts (HIPAA Action Plan - Pilot, HIPAA Evidence - Register, HIPAA Control Map - Safeguards) and the live role-separation snapshot: a safeguard-status rollup grouped by HIPAA safeguard family (Administrative / Physical / Technical), the evidence/test-status breakdown, the Compliance Manager role separation, and licensing context. It is a MANAGEMENT rollup — the authoritative score and export live in the Purview portal's Compliance Manager. Read-only. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\CMPHIPAA-Report.ps1 -ArtifactsDir .\HIPAA-artifacts Optionally -OutFile .\HIPAA-Posture-Report.csv to save the rollup. PowerShell 5.1+ / 7+. The role-separation section uses ExchangeOnlineManagement (Connect-IPPSSession); use -SkipRoles to report from artifacts only. Interactive modern-auth sign-in; no secrets in code. EXPECTED RESULTS A console rollup: counts of actions by implementation status and by safeguard family, evidence auto-vs-manual and test-status counts, and the role-group membership. With -OutFile, the per-action rollup is written to CSV. A reminder that the authoritative score is the portal's Compliance Manager export. .NOTES Purview category — HIPAA compliance program. Read-only management rollup; not the authoritative score. Whether the posture satisfies the HIPAA obligation is a compliance/privacy/legal determination. > [CmdletBinding()] param([string]$ArtifactsDir = (Join-Path (Get-Location) 'HIPAA-artifacts'), [string]$OutFile, [switch]$SkipRoles, [string]$UserPrincipalName)

How to run: powershell -ExecutionPolicy Bypass -File .\CMPHIPAA-Report.ps1 -ArtifactsDir .\HIPAA-artifacts Optionally -OutFile .\HIPAA-Posture-Report.csv to save the rollup. PowerShell 5.1+ / 7+. The role-separation section uses ExchangeOnlineManagement (Connect-IPPSSession); use -SkipRoles to report from artifacts only. Interactive modern-auth sign-in; no secrets in code. EXPECTED RESULTS A console rollup: counts of actions by implementation status and by safeguard family, evidence auto-vs-manual and test-status counts, and the role-group membership. With -OutFile, the per-action rollup is written to CSV. A reminder that the authoritative score is the portal's Compliance Manager export.

.NOTES Purview category — HIPAA compliance program. Read-only management rollup; not the authoritative score. Whether the posture satisfies the HIPAA obligation is a compliance/privacy/legal determination. > [CmdletBinding()] param([string]$ArtifactsDir = (Join-Path (Get-Location) 'HIPAA-artifacts'), [string]$OutFile, [switch]$SkipRoles, [string]$UserPrincipalName)

CMPHIPAA-Set-Scope.ps1

Purpose: Adds or removes a member of a Compliance Manager role group (Administrators / Assessors / Contributors / Readers) to enforce the least-privilege separation the program requires — the HIPAA Security/Privacy Officer and auditors as Readers, action owners as Contributors, assessment leads as Assessors, program owners as Administrators. Runs with -WhatIf by default and only PRINTS the Add-/Remove-RoleGroupMember it would run; add -Commit to apply. HOW TO RUN Preview: powershell -ExecutionPolicy Bypass -File .\CMPHIPAA-Set-Scope.ps1 -Action Add \ -RoleGroup 'Compliance Manager Readers' -Member officer@contoso.com Apply: ... -Action Add -RoleGroup 'Compliance Manager Readers' -Member officer@contoso.com -Commit PowerShell 5.1+ / 7+. Requires ExchangeOnlineManagement (Connect-IPPSSession) with an admin able to manage role groups. Interactive modern-auth sign-in; no secrets in code. EXPECTED RESULTS Dry-run prints the exact membership change it would make (no change applied). With -Commit, the member is added/removed and the resulting membership is printed for confirmation. .NOTES Purview category — HIPAA compliance program. Write-capable (role membership only); -WhatIf by default. Grant the MINIMUM role each person needs; keep the Security/Privacy Officer and auditors read-only. Verify the exact role-group names in your tenant — Purview role naming evolves. > [CmdletBinding()] param([Parameter(Mandatory)][ValidateSet('Add','Remove')] [string]$Action, [Parameter(Mandatory)][ValidateSet('Compliance Manager Administrators', 'Compliance Manager Assessors', 'Compliance Manager Contributors', 'Compliance Manager Readers')] [string]$RoleGroup, [Parameter(Mandatory)][string]$Member, # UPN / identity of the person [string]$UserPrincipalName, # optional admin UPN for Connect-* [switch]$Commit # apply; without it, dry-run only)

How to run: Preview: powershell -ExecutionPolicy Bypass -File .\CMPHIPAA-Set-Scope.ps1 -Action Add \ -RoleGroup 'Compliance Manager Readers' -Member officer@contoso.com Apply: ... -Action Add -RoleGroup 'Compliance Manager Readers' -Member officer@contoso.com -Commit PowerShell 5.1+ / 7+. Requires ExchangeOnlineManagement (Connect-IPPSSession) with an admin able to manage role groups. Interactive modern-auth sign-in; no secrets in code. EXPECTED RESULTS Dry-run prints the exact membership change it would make (no change applied). With -Commit, the member is added/removed and the resulting membership is printed for confirmation. .NOTES Purview category — HIPAA compliance program. Write-capable (role membership only); -WhatIf by default. Grant the MINIMUM role each person needs; keep the Security/Privacy Officer and auditors read-only. Verify the exact role-group names in your tenant — Purview role naming evolves. > [CmdletBinding()] param([Parameter(Mandatory)][ValidateSet('Add','Remove')] [string]$Action, [Parameter(Mandatory)][ValidateSet('Compliance Manager Administrators', 'Compliance Manager Assessors', 'Compliance Manager Contributors', 'Compliance Manager Readers')] [string]$RoleGroup, [Parameter(Mandatory)][string]$Member, # UPN / identity of the person [string]$UserPrincipalName, # optional admin UPN for Connect-* [switch]$Commit # apply; without it, dry-run only)

CMPHIPAA-Validation.ps1

Purpose: Read-only check of the Microsoft 365 technical signals that back the safeguard-mapped improvement actions, so you know which can auto-pass in Compliance Manager and which need manual evidence: unified audit ingestion (§164.312(b)), DLP / retention / sensitivity-label presence for ePHI

(§164.308(a)(4), §164.312(a),(c),(e)), and Conditional Access / MFA (§164.312(a),(d), via Graph). Confirms present-vs-absent; it does NOT judge adequacy — that is a compliance/privacy/legal call. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\CMPHIPAA-Validation.ps1 PowerShell 5.1+ / 7+. Requires ExchangeOnlineManagement (Connect-IPPSSession) and, for the Conditional Access section, Microsoft.Graph with delegated Policy.Read.All. Interactive modern-auth sign-in; no secrets in code. Use -SkipGraphCA to skip the Conditional Access section. EXPECTED RESULTS A PASS/REVIEW line per safeguard signal: audit ingestion ON = PASS; >=1 DLP / retention / label policy present = REVIEW (confirm one targets ePHI); >=1 enabled Conditional Access policy = REVIEW. Absent signals are reported so the matching action is NOT marked implemented without proof. .NOTES Purview category — HIPAA compliance program. Read-only. Presence != adequacy; whether a control satisfies a HIPAA safeguard is a compliance/privacy/legal determination. Feature availability is licensing-/tenant-dependent — verify against your entitlements. > [CmdletBinding()] param([string]$UserPrincipalName, [switch]$SkipGraphCA # skip the Conditional Access / MFA section if Graph is unavailable)

How to run: powershell -ExecutionPolicy Bypass -File .\CMPHIPAA-Validation.ps1 PowerShell 5.1+ / 7+. Requires ExchangeOnlineManagement (Connect-IPPSSession) and, for the Conditional Access section, Microsoft.Graph with delegated Policy.Read.All. Interactive modern-auth sign-in; no secrets in code. Use -SkipGraphCA to skip the Conditional Access section. EXPECTED RESULTS A PASS/REVIEW line per safeguard signal: audit ingestion ON = PASS; >=1 DLP / retention / label policy present = REVIEW (confirm one targets ePHI); >=1 enabled Conditional Access policy = REVIEW. Absent signals are reported so the matching action is NOT marked implemented without proof. .NOTES Purview category — HIPAA compliance program. Read-only. Presence != adequacy; whether a control satisfies a HIPAA safeguard is a compliance/privacy/legal determination. Feature availability is licensing-/tenant-dependent — verify against your entitlements. > [CmdletBinding()] param([string]$UserPrincipalName, [switch]$SkipGraphCA # skip the Conditional Access / MFA section if Graph is unavailable)